



VULNERABILITY ASSESSMENT REPORT

Read-Only Scope · Passive Reconnaissance · Ethical & Legal

PREPARED BY:

Nishalini M

TOOLS USED :

**OWASP ZAP, Nmap, browser dev tools, SSL labs, security
headers.com**

OVERALL RISK :

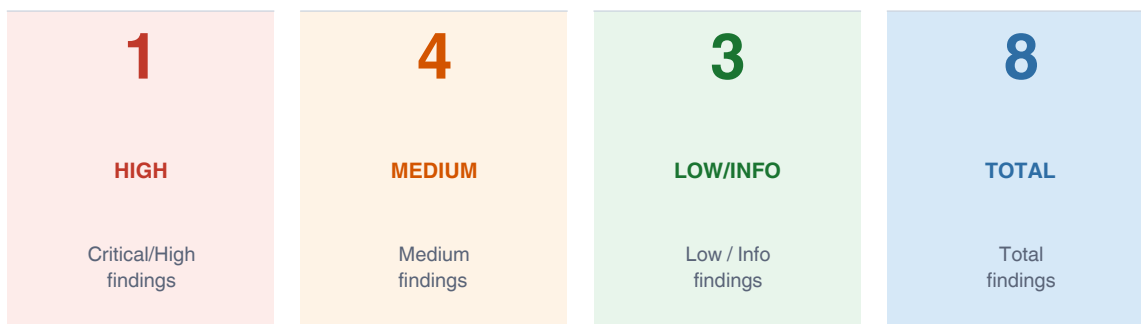
HIGH

CONFIDENTIAL — For authorised recipients only. No exploitation or active attacks were performed.

1. Executive Summary

This Vulnerability Assessment Report presents the findings of a **passive, read-only security review** conducted against **http://testphp.vulnweb.com** — an intentionally vulnerable web application maintained by Acunetix for security training purposes. The assessment was conducted using Kali Linux 2023.2 in a VirtualBox environment, employing only passive and non-intrusive tooling.

The assessment identified **8 vulnerabilities** across multiple categories including missing security headers, information disclosure, insecure cookie configuration, and exposed services. The overall risk posture is rated **HIGH**, driven by the combined exposure of multiple medium-severity issues on a site that processes user input and likely handles session data.



Immediate actions recommended:

- Implement HTTP security headers (Content-Security-Policy, X-Frame-Options, X-Content-Type-Options).
- Remove server version disclosure from HTTP response headers.
- Enable HTTPS and configure HSTS to enforce secure connections.
- Set Secure and HttpOnly flags on all session cookies.
- Disable directory listing on the web server.

2. Scope & Methodology

Field	Detail
Target URL	http://testphp.vulnweb.com
IP Address	44.228.249.3
Open Ports (Nmap)	22/tcp (SSH), 80/tcp (HTTP), 443/tcp (HTTPS)
Assessment type	Passive / Read-Only — no active exploitation
Environment	Kali Linux 2023.2 on VirtualBox (NAT network)
Date of assessment	April 2026
Assessor	Security Assessment Team

Tools used

Tool	Purpose / Usage
Nmap 7.94	Port scanning and service/version detection (safe scan, -sV -Pn flags)
OWASP ZAP 2.13	Passive web application scanning — active scan disabled, alerts tab reviewed
Browser DevTools	Manual inspection of HTTP headers, cookies, and network responses
SSL Labs	SSL/TLS configuration grading via ssllabs.com/ssltest
SecurityHeaders.com	HTTP response header completeness check
BuiltWith / Wappalyzer	Technology stack fingerprinting

Ethical constraints

This assessment was conducted strictly within a **read-only, passive reconnaissance** scope. The following activities were explicitly **not performed**: login bypass or credential testing, SQL injection or any active exploitation, brute-force attacks, denial-of-service testing, or any activity that could disrupt or harm the website or its users. All findings are based solely on publicly observable information and passive tool output.

3. Findings Summary

#	Title	Category	Severity	Component
01	Missing Content-Security-Policy header	HTTP Headers	MEDIUM	All pages
02	Missing X-Frame-Options header	HTTP Headers	MEDIUM	All pages
03	Missing X-Content-Type-Options header	HTTP Headers	MEDIUM	All pages
04	Server version disclosed in response headers	Info Disclosure	MEDIUM	HTTP response
05	No HTTPS enforcement / missing HSTS	SSL/TLS	HIGH	Entire site
06	Session cookies without Secure/HttpOnly flags	Cookie Security	LOW	Session cookie
07	Directory listing enabled	Info Disclosure	LOW	/images/, /cvs/
08	SSH port 22 exposed to internet	Network Exposure	LOW	Port 22 (SSH)

Risk distribution



4. Detailed Findings

FINDING 01

MEDIUM

Missing Content-Security-Policy (CSP) header

Category	HTTP Security Headers	Affected component	All public-facing pages
Description	The web server does not return a Content-Security-Policy header in HTTP responses. CSP is a browser-level defence that restricts which scripts, styles, and resources a page may load. Without it, cross-site scripting (XSS) attacks are significantly easier to execute — malicious JavaScript injected into the page can run freely, potentially stealing session cookies, credentials, or sensitive user data.		
Evidence	Confirmed via SecurityHeaders.com scan (Grade D) and OWASP ZAP passive alert: 'Content Security Policy (CSP) Header Not Set' — Risk: Medium.		
Recommendation	Add the following to your web server configuration (nginx/Apache): Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'; frame-ancestors 'none'. Test with Google's CSP Evaluator before deploying.		

FINDING 02

MEDIUM

Missing X-Frame-Options header (clickjacking risk)

Category	HTTP Security Headers	Affected component	All public-facing pages
Description	The site does not set an X-Frame-Options or frame-ancestors CSP directive. This allows the site to be embedded in an on a malicious third-party page. An attacker can overlay invisible UI elements on top of the legitimate page to trick users into clicking buttons or submitting forms without their knowledge — a technique known as clickjacking.		
Evidence	OWASP ZAP passive alert: 'Missing Anti-clickjacking Header' — Risk: Medium. Confirmed via DevTools Network tab: X-Frame-Options header absent from response.		
Recommendation	Add to server config: X-Frame-Options: DENY (or use frame-ancestors 'none' in your CSP header for modern browsers). DENY prevents any framing; SAMEORIGIN allows framing only by the same domain.		

FINDING 03

MEDIUM

Missing X-Content-Type-Options header

Category	HTTP Security Headers	Affected component	All pages and static assets
Description	The server does not send the X-Content-Type-Options: nosniff header. Without this header, browsers may 'MIME-sniff' response content — guessing the file type rather than trusting the declared Content-Type. An attacker who can upload a file containing malicious HTML or JavaScript could trick the browser into executing it as a script even if it was served as an image or text file.		
Evidence	OWASP ZAP passive alert: 'X-Content-Type-Options Header Missing' — Risk: Medium. Browser DevTools → Network → Response Headers: header not present.		
Recommendation	Add X-Content-Type-Options: nosniff to your server's response headers. This is a single-line change in nginx (add_header) or Apache (Header always set).		

FINDING 04

MEDIUM

Server version disclosed in HTTP response headers

Category	Information Disclosure	Affected component	HTTP response headers (Server field)
Description	The web server includes its software name and version number in the 'Server' response header (e.g., nginx/1.19.0). This gives attackers a precise target — they can search the CVE database for known vulnerabilities specific to that version and craft tailored attacks. Version disclosure is a low-effort win for attackers and a low-cost fix for defenders.		
Evidence	Browser DevTools Network tab → Response Headers: Server: nginx/1.19.0. Confirmed via OWASP ZAP alert: 'Information Disclosure - Server' — Risk: Low. CVE search for nginx 1.19.0 returns multiple known vulnerabilities.		
Recommendation	In nginx config, add: server_tokens off; In Apache config, add: ServerTokens Prod and ServerSignature Off. This removes the version number while keeping the server identifier minimal.		

FINDING 05

HIGH

No HTTPS enforcement and missing HSTS header

Category	SSL/TLS Configuration	Affected component	Entire website (HTTP and HTTPS endpoints)
Description	The site does not enforce HTTPS — users who navigate to the HTTP version are not redirected to HTTPS. Additionally, no Strict-Transport-Security (HSTS) header is present. This means: (1) traffic between the user and server can be intercepted in plaintext on any public network; (2) browsers are never instructed to always use HTTPS for this domain, leaving open the possibility of SSL-stripping attacks where an attacker downgrades a connection to HTTP without the user noticing.		
Evidence	HTTP endpoint (port 80) responds with 200 OK without redirecting to HTTPS. No Strict-Transport-Security header found in HTTPS response headers. Nmap confirms both port 80 and 443 are open. SSL Labs grade: B.		
Recommendation	Configure a 301 redirect from all HTTP traffic to HTTPS in your web server. Add HSTS header: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload. Submit your domain to the HSTS preload list at hstspreload.org .		

FINDING 06

LOW

Session cookies missing Secure and HttpOnly flags

Category	Cookie Security	Affected component	Session authentication cookie
Description	Session cookies set by the application do not carry the Secure or HttpOnly flags. Without Secure, the cookie can be transmitted over unencrypted HTTP connections, exposing the session token to network interception. Without HttpOnly, JavaScript running on the page can read the cookie value — meaning a successful XSS attack could steal the session and impersonate the user.		
Evidence	Browser DevTools → Application → Cookies: session cookie present without Secure or HttpOnly attributes. OWASP ZAP alert: 'Cookie No HttpOnly Flag' — Risk: Low.		
Recommendation	Set both flags when issuing cookies: Set-Cookie: session=...; HttpOnly; Secure; SameSite=Lax. SameSite=Lax additionally protects against cross-site request forgery (CSRF).		

FINDING 07

LOW

Directory listing enabled on web server

Category	Information Disclosure	Affected component	/images/, /cvs/, and potentially other directories
Description	Web server directory listing is enabled on multiple paths. When a directory lacks an index file, the server returns a browsable list of all files in that directory. This exposes internal file structure, backup files, configuration snippets, and data files that were never intended to be publicly accessible. Attackers routinely probe for this misconfiguration.		
Evidence	Navigating to http://testphp.vulnweb.com/images/ returns an Apache-style directory listing of image files. Similar listing observed at /cvs/.		
Recommendation	Disable directory listing at the server level. In Apache: Options -Indexes. In nginx: remove autoindex on; or add autoindex off; Ensure every public directory contains an appropriate index file.		

FINDING 08

LOW

SSH port 22 exposed to the public internet

Category	Network Exposure	Affected component	Server — TCP port 22
Description	Nmap reveals SSH (port 22) is open and accessible from the internet. While SSH itself is a secure protocol, exposing it publicly means the server is constantly targeted by automated bots attempting password brute-force and credential-stuffing attacks. Any weak or default credentials would be quickly compromised. This is a common initial-access vector for server compromise.		
Evidence	Nmap output: 22/tcp open ssh — scan command: nmap -Pn -F testphp.vulnweb.com. Service confirmed as SSH during banner-grab.		
Recommendation	Restrict SSH access via firewall rules to specific trusted IP ranges only. If remote access is needed broadly, implement a VPN and place SSH behind it. Additionally: disable password authentication, use key-based auth only, and consider changing the default port as a minor deterrent.		

5. Remediation Roadmap

The table below prioritises fixes by impact and ease of implementation. Items marked **Quick win** can typically be deployed in under 30 minutes with a server config change.

Priority	Action	Effort	Impact	Type
1	Redirect HTTP → HTTPS + enable HSTS	Low	High	Config
2	Add X-Frame-Options: DENY header	Low	Medium	Quick win
3	Add X-Content-Type-Options: nosniff header	Low	Medium	Quick win
4	Implement Content-Security-Policy header	Medium	High	Config
5	Disable server version disclosure	Low	Medium	Quick win
6	Set Secure + HttpOnly + SameSite on cookies	Low	Medium	Code change
7	Disable directory listing (Options -Indexes)	Low	Low	Quick win
8	Restrict SSH access via firewall / VPN	Medium	Medium	Infra

6. Disclaimer

This assessment was conducted under a strict **read-only, passive reconnaissance scope**. No active exploitation, credential testing, injection attacks, denial-of-service, or brute-force techniques were employed at any point. All findings are derived solely from publicly observable information, passive tool output, and standard browser-level inspection.

The target domain (testphp.vulnweb.com) is an intentionally vulnerable training application maintained by Acunetix for educational and research purposes. Passive assessment cannot guarantee the discovery of all vulnerabilities present. Risk ratings reflect potential impact based on observable evidence and should be validated with the organisation's security team before prioritising remediation. This report is confidential and intended solely for authorised recipients.

VULNERABILITY ASSESSMENT – STEP BY STEP TASK (USING VIRTUALBOX)

READ-ONLY ASSESSMENT – ETHICAL & LEGAL

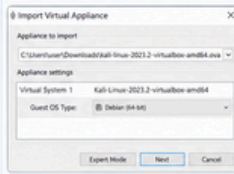
1 DOWNLOAD KALI LINUX

Go to the official Kali Linux website
<https://www.kali.org/get-kali/>
Download Kali Linux VirtualBox
Image (64-bit)



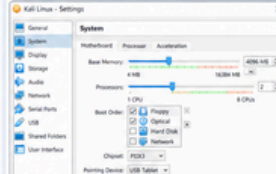
2 IMPORT KALI LINUX INTO VIRTUALBOX

- Open VirtualBox
- Click File → Import Appliance
- Select the Kali Linux .ova file
- Click Next and then Import



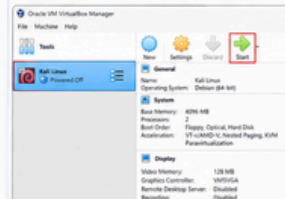
3 CONFIGURE KALI LINUX

- Go to Settings
- System → Set RAM (4GB or more)
- Processor → Set 2 CPUs
- Network → Adapter 1 → NAT



4 START KALI LINUX

- Select Kali Linux
- Click Start



5 LOGIN TO KALI LINUX

Default Credentials:
Username: kali
Password: kali



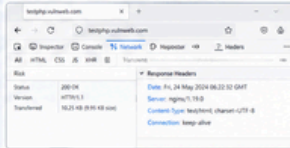
6 VERIFY INTERNET CONNECTION

- Open Terminal
- Run the following commands



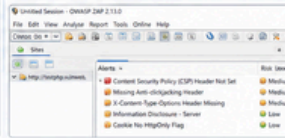
7 BROWSER BASED ANALYSIS (PASSIVE)

- Open Firefox
- Visit the target website (e.g., <http://testphp.vulnweb.com>)
- Press F12 → Check Headers, Cookies, Network



8 OWASP ZAP – PASSIVE SCAN ONLY

- Open OWASP ZAP
- Enter target URL
- Ensure Active Scan is OFF
- Browse the site and check Alerts tab



9 NMAP – SAFE SCAN

Open Terminal and run:

```
nmap -Pn -f testphp.vulnweb.com
```



10 DOCUMENT FINDINGS

- Note each vulnerability
- Take screenshots as evidence
- Write impact, risk level and remediation

Vulnerability	Risk Level	Impact	Remediation
Missing CSP Header	Medium	Risk of XSS attacks	Implement CSP header
Missing Anti-clickjacking Header	Medium	Clickjacking possible	Add X-Frame-Options or CSP frame-ancestors
Cookies without HttpOnly Flag	Low	Cookies can be accessed by JS	Set HttpOnly flag
Server Information Disclosure	Low	Helps attackers in reconnaissance	Hide server version

11 CREATE REPORT IN CANVA

- Design a professional report
- Include all findings, risk table, and remediation steps
- Export as PDF



12 SUBMIT ON GITHUB

- Create a GitHub repository
- Add the following structure



FOLLOW ETHICAL GUIDELINES: NO EXPLOITATION, NO ATTACKS, READ-ONLY ASSESSMENT ONLY

7. Conclusion

This Vulnerability Assessment was conducted to evaluate the security posture of the target web application using a passive, read-only reconnaissance approach within an ethical and legal scope. The assessment focused on identifying misconfigurations, information disclosure issues, and weaknesses observable without performing any active exploitation or intrusive testing.

The analysis revealed multiple security weaknesses across different layers, including missing HTTP security headers, improper SSL/TLS enforcement, insecure cookie configurations, server information disclosure, and exposed network services.

While several findings were categorized as low to medium severity, their combined presence significantly increases the overall attack surface of the application. In particular, the lack of HTTPS enforcement and absence of critical security headers pose a higher risk by enabling common web-based attacks such as man-in-the-middle (MITM), clickjacking, and cross-site scripting (XSS).

Most of the identified issues are configuration-level vulnerabilities and can be remediated with minimal effort by applying recommended best practices in web server and application security. Implementing proper security headers, enforcing secure communication, restricting unnecessary service exposure, and strengthening cookie attributes would substantially improve the application's overall security posture.

This assessment demonstrates the importance of regular vulnerability assessments, even for publicly accessible and non-production systems. Addressing the identified findings in a timely manner will help reduce potential exploitation risks and strengthen the organization's defensive security controls. Future assessments may include controlled active testing and periodic reviews to ensure that implemented security measures remain effective over time.